

Create a Security Architecture Diagram

Estimated time needed: 30 minutes

Security architecture diagrams are visual representations that show how security controls, components, and data flows are organized to protect an organization's systems and information. As an architect stepping into cybersecurity, learning to create these diagrams is essential for communicating security designs to stakeholders, identifying vulnerabilities, and planning security implementations.

In this lab, you'll learn the fundamental elements of a security architecture diagram and create a simple diagram for a web application scenario.

Objectives

After completing this lab, you will be able to:

1. Identify the core components of a security architecture diagram
2. Understand security zones and network segmentation concepts
3. Place security controls appropriately in an architecture
4. Create a basic security architecture diagram for a web application

Exercise 1: Understanding security architecture components

In this exercise, you will learn about the essential building blocks that make up a security architecture diagram.

What you'll need

- Any diagramming tool you're comfortable with (draw.io, Visio, Lucidchart, PowerPoint, or even pen and paper)
- The scenario described below

The scenario

You're designing security for a simple e-commerce web application. The application has:

- A public-facing website where customers browse and shop
- A database that stores customer information and orders
- An administrative portal for employees to manage products and orders

1. Identify the security zones

Before drawing anything, you need to understand security zones. These are logical groupings of systems based on their security requirements and trust levels.

For our scenario, identify these three zones:

- **Internet Zone (Untrusted):** Where external users and potential threats exist
- **DMZ Zone (Semi-Trusted):** Where public-facing services live, exposed to the internet but with some protection
- **Internal Zone (Trusted):** Where sensitive systems like databases and internal applications reside

Think of zones like rooms in a house with different security levels: your front porch (Internet), your living room (DMZ), and your bedroom with the safe (Internal).

2. List the core components

Write down or mentally note these essential components you'll need in your diagram:

- **Firewall:** Acts as a security guard, controlling what traffic can pass between zones
- **Web Server:** Hosts the public website (goes in the DMZ)
- **Application Server:** Runs the business logic (goes in the Internal zone)
- **Database Server:** Stores sensitive data (goes in the Internal zone)
- **Users/Actors:** Customers (from Internet) and Administrators (from Internal network)

The web server needs to be accessible from the internet, but we want to keep the database as far from direct internet access as possible.

3. Understand the traffic flow

Security architecture isn't just about placing components. It is about understanding how data moves securely:

- Customers connect from the Internet → through Firewall → to Web Server
- Web Server communicates → through internal Firewall → to Application Server
- Application Server queries → through internal controls → Database Server
- Administrators connect from Internal network → through Firewall → to Admin Portal

Notice how every connection crosses a security control? That's intentional. We never allow direct access across zones without security validation.

Exercise 2: Creating your security architecture diagram

In this exercise, you will create your first security architecture diagram using the components and concepts from Exercise 1.

Task A: Set-up your diagram canvas

1. Create three horizontal zones

Open your diagramming tool and create three distinct horizontal sections (you can use rectangles or just horizontal lines to separate them):

- Top section: Label it "Internet Zone (Untrusted)"
- Middle section: Label it "DMZ (Demilitarized Zone)"
- Bottom section: Label it "Internal Zone (Trusted)"

Using horizontal zones is a common convention—the most trusted areas are typically shown at the bottom or center, with less trusted areas above or to the sides.

2. Add visual distinction

Make each zone visually distinct by using:

- Different background colors (light red for Internet, yellow for DMZ, green for Internal), or
- Different border styles if you prefer grayscale, or
- Simple shading/patterns

This visual separation helps viewers quickly understand trust boundaries, even if they're not security experts.

Task B: Place security components

1. Position the Firewalls (security boundaries)

Place firewall icons or rectangles at the boundaries between zones:

- One between Internet Zone and DMZ (label it "External Firewall")
- One between DMZ and Internal Zone (label it "Internal Firewall")

Think of firewalls as checkpoints. Just like airport security checks passengers before they enter secure areas, firewalls inspect network traffic before allowing it through.

2. Add the servers and components

Place these components in their appropriate zones:

- In the **Internet Zone**: Add an icon representing "External Users/Customers"
- In the **DMZ**: Add a "Web Server" icon (this handles customer requests)
- In the **Internal Zone**: Add two icons:
 - "Application Server" (processes business logic)
 - "Database Server" (stores customer data)
- Also in the **Internal Zone**: Add "Admin Users/IT Staff"

Label each component clearly. The goal is to have clarity.

3. Draw the connection lines (traffic flows)

Connect your components with arrows to show how traffic flows:

- Draw an arrow from External Users → through External Firewall → to Web Server
- Draw an arrow from Web Server → through Internal Firewall → to Application Server
- Draw an arrow from Application Server → to Database Server
- Draw an arrow from Admin Users → through Internal Firewall → to Application Server (for admin functions)

Add labels to the arrows indicating the protocol or purpose:

- "HTTPS (Port 443)" for web traffic
- "Internal API" for application communication
- "Database Queries" for database access

Task C: Add security controls and annotations

1. Document key security controls

Add text boxes or notes to highlight important security measures:

- Next to External Firewall: "Allows only HTTPS (443) inbound, blocks all other ports"
- Next to Web Server: "SSL/TLS encryption for all customer data"
- Next to Internal Firewall: "Restricts access to authorized internal traffic only"
- Next to Database: "Encrypted at rest, access logged"

These annotations transform your diagram from a simple network map into a security architecture diagram. They show *how* security is implemented, not just *where* components exist.

2. Add a legend (optional but recommended)

Create a small legend box explaining your symbols:

- What shape represents servers
- What shape represents firewalls
- What arrow styles represent (solid = encrypted, dashed = internal, etc.)
- What colors represent (if using colors)

3. Review your diagram

Ask yourself these questions to verify your diagram is complete:

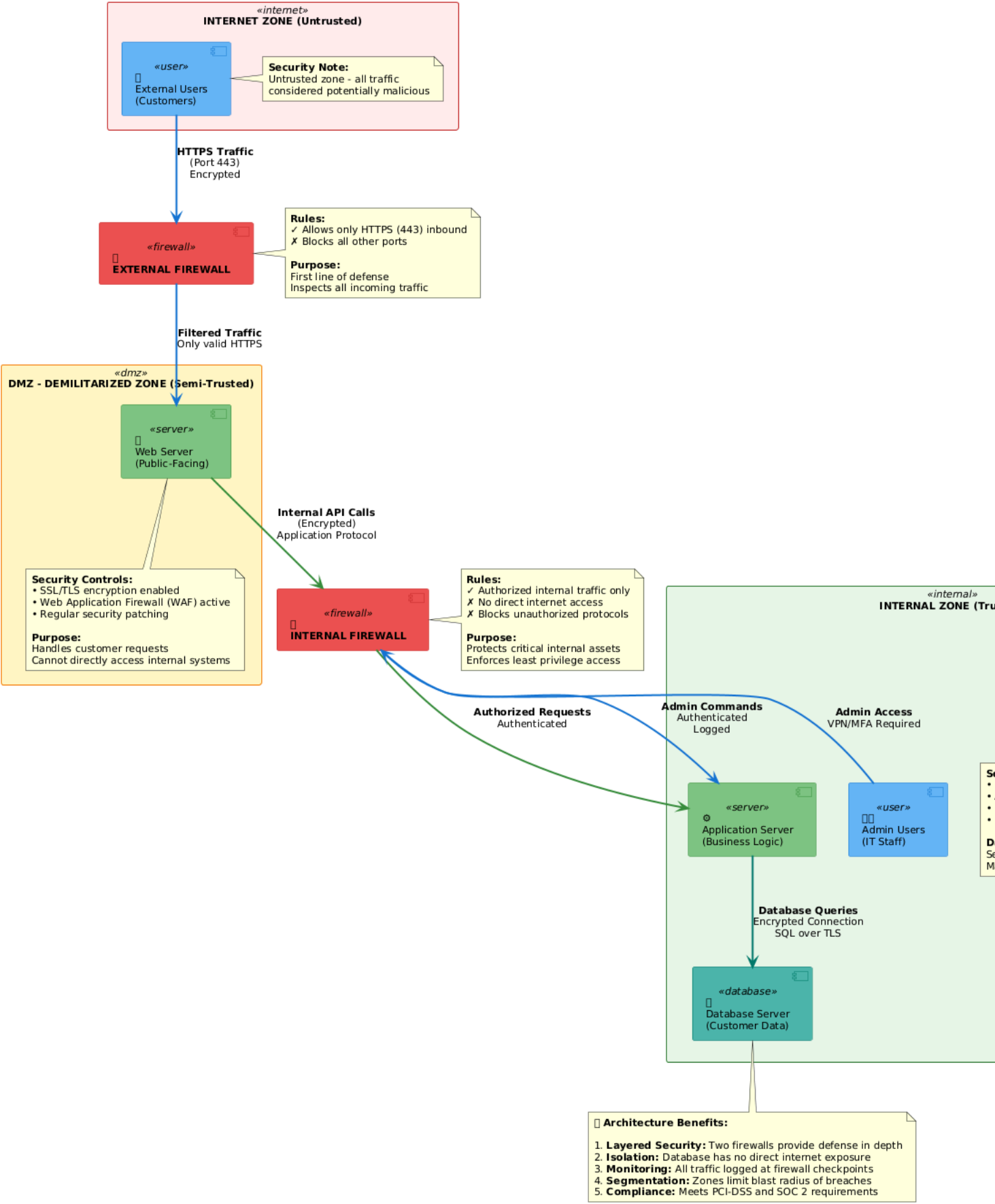
- Can I trace how a customer request flows from the internet to the database?
- Are there security controls (firewalls) at every zone boundary?
- Is sensitive data (database) furthest from untrusted zones?
- Would a non-security person understand the basic flow?
- Are all components labeled clearly?

If you answered "yes" to these questions, congratulations! You've created a functional security architecture diagram.

Sample architecture diagram

Here is a sample architecture diagram for your reference. Your architecture may contain more or less details based on your requirements. Use this sample architecture for reference and validate your work.

Security Architecture Diagram - E-commerce Web Application



Color	Zone/Component
Internet Zone	Internet Zone
DMZ Zone	DMZ Zone
Internal Zone	Internal Zone
Firewall	Firewall

	Users/Actors
	Servers
	Database

Key Security Principles

- Defense in Depth: Multiple layers of security
- Network Segmentation: Isolating critical systems
- Least Privilege: Minimizing access
- Controlled Access: All access is monitored and logged

Three-Zone Security Model with Defense in Depth

Summary and next steps

You've now created a security architecture diagram! You learned about security zones, understood the principle of defense in depth (multiple layers of security), and documented how components interact across security boundaries.

Key takeaways:

- Security architecture diagrams communicate how security is designed into systems
- Security zones separate systems by trust level (Internet, DMZ, Internal)
- Firewalls act as gatekeepers between zones
- Traffic flow arrows show how data moves through security controls
- Annotations explain what security measures are in place

Author(s)

- [Ramanujam Srinivasan](#)



Skills Network